

Subnets, Security Groups và Network ACLs

AWS Cloud Practitioner Essentials › Module 5: Networking › Introducing Network Components on AWS

(Nguồn ghi "Introducing"; đúng chính tả là "Introducing".)

★ Mục Tiêu Bài Học

- Mô tả cách **lưu lượng mạng** (network traffic) hoạt động trong VPC.
- Mô tả cách **security group** hoạt động (stateful).
- Mô tả cách **network ACL** hoạt động (stateless).
- Xác định ai chịu trách nhiệm bảo mật subnet bằng security group và network ACL theo **Shared Responsibility Model**.

★ Subnet

Subnet là một phần của VPC, dùng để **nhóm các tài nguyên** theo nhu cầu bảo mật hoặc vận hành.

Subnet có thể là public hoặc private.

Trong VPC, có thể đặt quy tắc cho phép tài nguyên ở các subnet khác nhau giao tiếp với nhau.

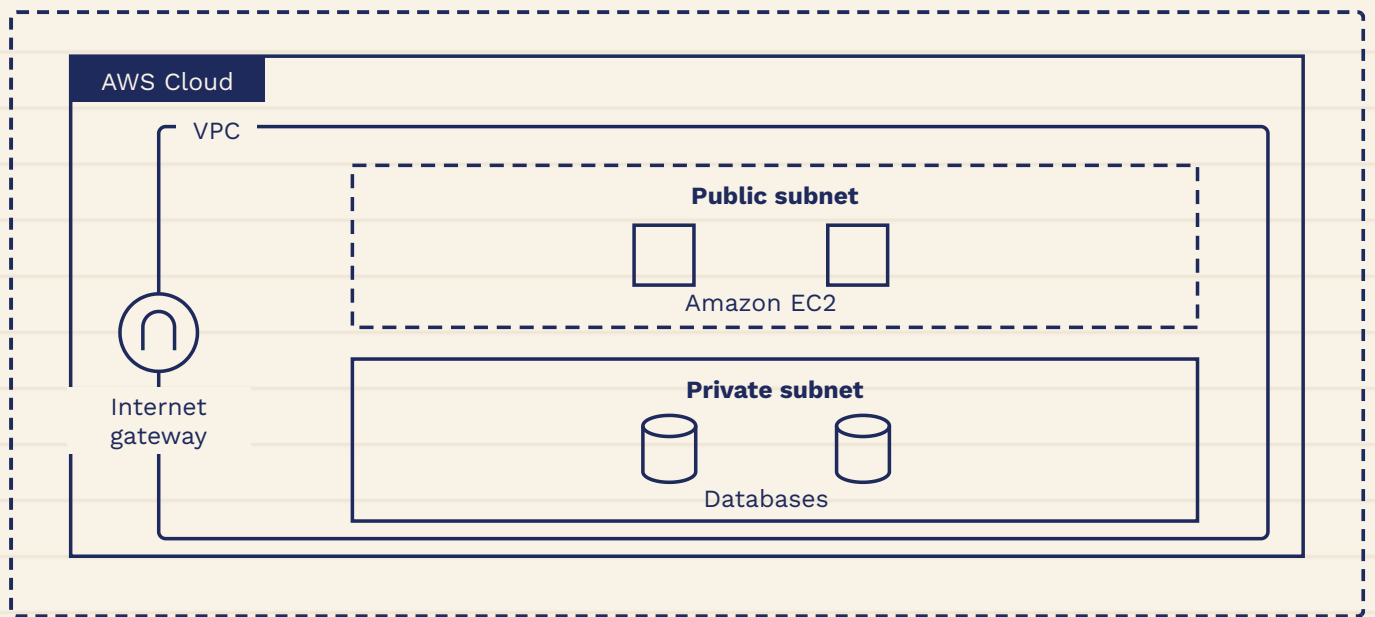
Vì Sao Cần Học?

Security group và network ACL là hai cách **mạnh và linh hoạt** để kiểm soát lưu lượng trong VPC. Dùng cả hai giúp đáp ứng yêu cầu của ứng dụng và đảm bảo bảo mật mạng cơ bản.

Đặc Điểm Của Subnet

- **Public subnet:** chứa tài nguyên cần truy cập công khai, ví dụ website của cửa hàng online.
- **Private subnet:** chỉ truy cập qua mạng riêng, ví dụ database chứa thông tin cá nhân và lịch sử đơn hàng của khách.
- Một subnet nằm trong một AZ.

★ Sơ Đồ: Public Subnet Và Private Subnet



★ Lưu Lượng Mạng Trong VPC

Khi khách hàng yêu cầu dữ liệu từ ứng dụng trên AWS Cloud, yêu cầu được gửi dưới dạng **gói tin** (packet) — đơn vị dữ liệu gửi qua internet hoặc mạng. Gói tin vào VPC qua **internet gateway**. Trước khi vào hoặc ra khỏi subnet, gói tin phải qua nhiều bước kiểm tra quyền, trong đó có network ACL của subnet đích.



Quyền do network ACL quy định (cho phép hay từ chối) dựa trên **ai gửi** gói tin và **cách** gói tin giao tiếp với tài nguyên trong subnet.

★ Network ACL

Network ACL là **tường lửa ảo** (virtual firewall) kiểm soát lưu lượng vào và ra ở **cấp subnet**. Đây là thành phần VPC kiểm tra quyền của gói tin đối với subnet.

Ví dụ sân bay: du khách là gói tin, nhân viên kiểm soát hộ chiếu là network ACL. Nhân viên kiểm tra giấy tờ cả khi vào và khi rời nước, giống như network ACL kiểm tra quyền mỗi lần gói tin đi qua ranh giới subnet.

Đặc Điểm Của Network ACL

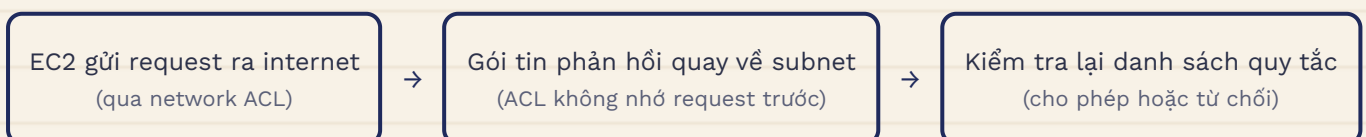
- Hoạt động ở **cấp subnet**.
- Kiểm soát cả **inbound** và **outbound**.
- Mỗi tài khoản AWS có một **default network ACL**; có thể dùng hoặc tạo **custom network ACL**.
- Mọi network ACL đều có một **explicit deny rule**: gói tin không khớp quy tắc nào sẽ bị từ chối.

★ Default Và Custom Network ACL

Loại	Hành vi
Default	→ Cho phép tất cả inbound và outbound; có thể sửa bằng cách thêm quy tắc riêng. (Sân bay: "mặc định ai cũng được vào, ai cũng được ra".)
Custom	→ Từ chối tất cả inbound và outbound cho đến khi thêm quy tắc cho phép. (Sân bay: "có tên trong danh sách thì được vào; không có trong danh sách của tôi thì không được ra".)
Explicit deny	→ Có ở mọi network ACL, đảm bảo gói tin không khớp quy tắc nào đều bị từ chối.

★ Stateless Packet Filtering

Network ACL lọc gói tin **không trạng thái** (stateless): nó **không nhớ gì** và kiểm tra gói tin đi qua ranh giới subnet theo cả hai chiều, inbound và outbound.



★ Security Group

Sau khi gói tin vào subnet, quyền của nó được đánh giá tiếp ở **cấp tài nguyên**, ví dụ Amazon EC2 instance. Security group là thành phần VPC kiểm tra quyền của gói tin đối với EC2 instance: một tường lửa ảo kiểm soát inbound và outbound cho các tài nguyên AWS cụ thể.

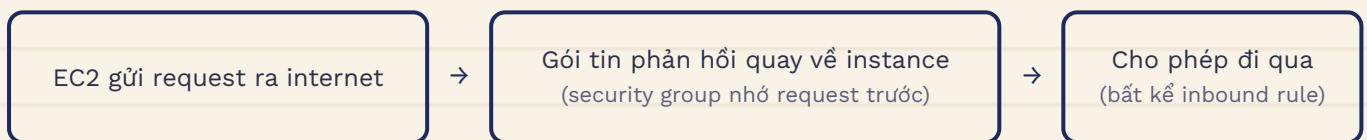
Ví dụ chung cư: khách là gói tin, người gác cửa là security group. Người gác kiểm tra danh sách khi khách đến, nhưng **không kiểm tra lại** khi khách ra về.

Đặc Điểm Của Security Group

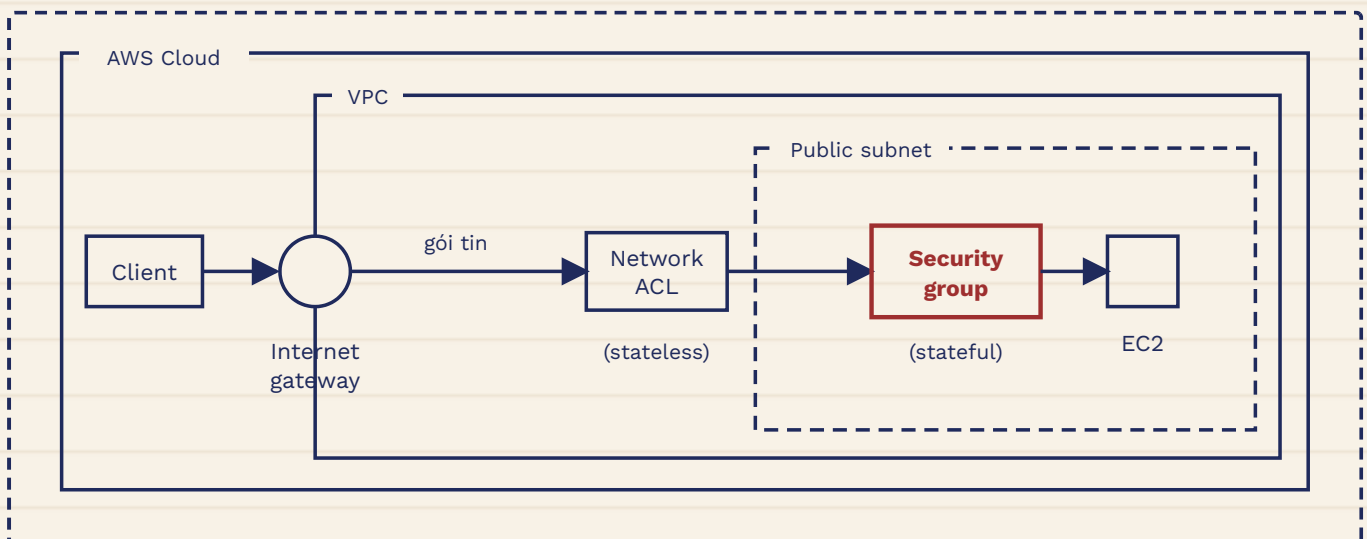
- Hoạt động ở **cấp tài nguyên** (EC2 instance).
- Mặc định: **từ chối mọi inbound, cho phép mọi outbound**.
- Thêm quy tắc riêng cho inbound và outbound; lưu lượng không khớp sẽ bị từ chối.
- Nhiều EC2 trong cùng VPC có thể dùng chung một security group hoặc mỗi instance một security group.

★ Stateful Packet Filtering

Security group lọc gói tin **có trạng thái** (stateful): nó **nhớ các quyết định** đã đưa ra cho gói tin đến.



★ Sơ Đồ: Đường Đi Của Gói Tin



Network ACL đứng ở ranh giới subnet; security group đứng ngay trước từng EC2 instance.

★ So Sánh Security Group Và Network ACL

Tiêu chí	Security Groups	Network ACLs
Scope (phạm vi)	Cấp instance (gắn vào EC2 instance)	Cấp subnet (liên kết với subnet)
State	Stateful (nhớ trạng thái)	Stateless (không nhớ trạng thái)
Rule types	Chỉ có quy tắc allow	Có cả quy tắc allow và deny
Return traffic	Lưu lượng trả về tự động được cho phép nếu inbound được cho phép	Lưu lượng trả về phải được cho phép ở cả hai chiều
Uses (công dụng)	Kiểm soát chi tiết cho từng EC2 instance	Kiểm soát rộng cho lưu lượng vào và ra subnet

Ghi chú: bảng gốc viết "implicitly allowed"; ý đúng là phải được cho phép **tường minh** (explicitly) ở cả hai chiều.

★ Shared Responsibility Model

Bảo mật subnet và tài nguyên trong VPC bằng network ACL và security group là **trách nhiệm của khách hàng**. Chúng thuộc nhóm **network traffic protection**, là lớp phòng thủ quan trọng bảo vệ ứng dụng **TRONG** đám mây (IN the cloud).

Bên	Phần việc
Khách hàng	Customer data; client-side data encryption; server-side encryption; network traffic protection; platform và application management; OS, network, firewall configuration
AWS	Software cho compute, storage, database và networking; hardware, AWS Global Infrastructure

★ Tự Kiểm Tra

Thành phần nào kiểm tra quyền ở cấp subnet? → **Network ACL**

Thành phần nào stateful? → **Security group**

Security group mặc định xử lý inbound và outbound thế nào? → **Chặn inbound, cho phép outbound**

Custom network ACL mới tạo cho phép gì? → **Không cho phép gì**

Ai cấu hình security group và network ACL? → **Khách hàng**

★ Tóm Tắt

Ghi Nhớ

- Subnet nhóm tài nguyên: **public** hoặc **private**.
- Network ACL**: cấp subnet, stateless, có allow và deny.
- Security group**: cấp instance, stateful, chỉ allow.
- Gói tin đi qua network ACL trước, rồi đến security group.
- Cả hai là **trách nhiệm của khách hàng**.